# Vila Aurora
# Segurança que preserva a operação local.

Relatório técnico do laboratório validado
**E1 - Arquitetura | E3 - Testes | E4 - Laudo forense**


| AUTOR | IDENTIFICAÇÃO |
|---|---|
| Caio Yudi Ozaki Godinho | RM 552505 \| Turma 4ECA |
| Engenharia da Computação | Professor Carlos Eduardo de Siqueira |


## Resultado disponível nesta versão

O laboratório local executou 25 de 25 testes de segurança com aprovação. MQTT e HTTPS utilizaram autenticação mútua por certificados; o painel aplicou MFA e controle por perfis. A reprodução de SQL Injection demonstrou a falha e a correção em bancos sintéticos separados.

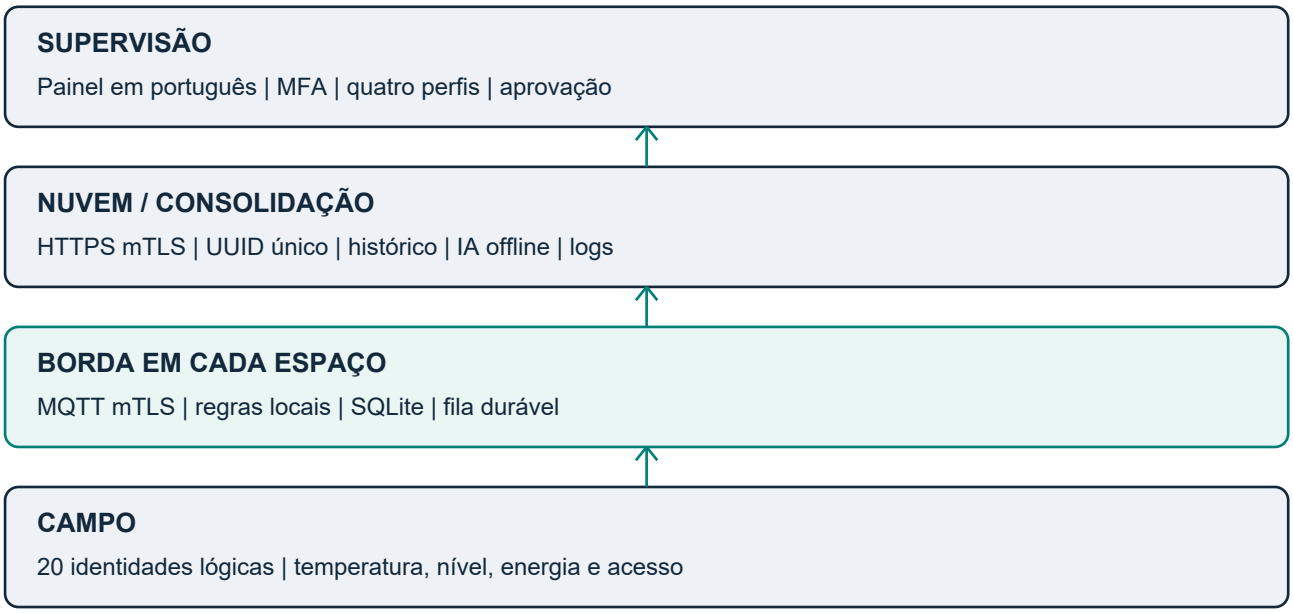
O ensaio de falha do coletor durou **1802.00 segundos**, manteve as cinco bordas lógicas e registrou **0 mensagens ausentes** na reconciliação.

**Escopo verificável:** cinco bordas lógicas em Windows e piloto UBS executado em Linux/Docker, com Mosquitto, WireGuard, redes separadas e corte de túnel por 30 minutos. Administração remota SSH/RDP não é oferecida. Sincronismo absoluto de relógio não confirmado; energia física não medida. Não há hardware de campo instalado.

Novembro de 2026 | Entrega individual | Dados exclusivamente sintéticos

# Arquitetura e problema atendido

O incidente fictício INC-VA-0712 combinou engenharia social, acesso remoto fraco, SQL Injection, dependência da nuvem e evidências insuficientes. A solução desloca a decisão de alarme para cada espaço e limita a confiança entre identidade, transporte, aplicação e operação.




| LOCAL | RECURSO PRIORITÁRIO | REGRA LOCAL DIDÁTICA |
|---|---|---|
| Centro | Energia e acesso | Alerta energia <20%; acesso como evento |
| Escola | Reservatório | Alerta nível <15%; comando crítico com aprovação |
| UBS | Câmara fria | Alerta temperatura fora de 2-8 °C |
| Horta/cozinha | Água e energia | Nível e energia acompanhados localmente |
| Abrigo | Continuidade em emergência | Mesmas regras; fila preservada sem coletor |

As faixas são parâmetros acadêmicos. O cenário usa quatro variáveis por local, totalizando 20 identidades lógicas; não inclui calibração, sensor de turbidez/cloro, controlador físico de fechadura ou certificação de cadeia fria.

# Fluxos, fronteiras de confiança e escolhas

| FLUXO | CONTROLE EFETIVO NO LABORATÓRIO |
|---|---|
| Sensor → borda | MQTT 3.1.1 sobre TLS; CN do certificado define tópico permitido. O client_id não autoriza outro sensor. |
| Borda → coletor | HTTPS mTLS; certificado edge-local vinculado ao site; UUID único; ACK do lote antes de retirar da outbox. |
| Operador → painel | HTTP apenas em loopback na versão nativa; senha derivada com PBKDF2 + TOTP e sessão curta; RBAC e CSRF. |
| Decisão crítica | Operador solicita; coordenação aprova. Só então o estado lógico pump_running muda para falso. |
| Eventos → detecção | JSONL central no host, cadeia SHA-256 e quatro regras de correlação; VPN testada por replay identificado. |

## Por que uma borda por espaço?

Uma falha na consolidação não deve impedir alerta de temperatura nem persistência. Cada borda mantém banco e broker próprios. O laboratório coloca esses componentes em threads do mesmo processo para caber no computador disponível; logo, uma falha do host ainda afeta todos. A implantação física exige separar os cinco nós.

## Armazenamento e limites

SQLite reduz manutenção e permite leitura parametrizada com conexão mode=ro e authorizer limitado ao histórico. Não se declarou um usuário PostgreSQL inexistente. A aplicação gravadora e o painel leitor usam permissões lógicas distintas, mas o sistema de arquivos do host continua parte da base de confiança.

O broker Python é um subconjunto didático, testado com cliente Paho: não oferece SUBSCRIBE, retained ou last-will. O piloto Docker utiliza Mosquitto real, com testes próprios de TLS, ACL e CRL. O correlacionador próprio não é Wazuh, e a IA desta versão faz avaliação offline do dataset, sem inferência contínua integrada ao atuador.

# Modelo de ameaças e continuidade

| AMEAÇA | CONTROLE / RESULTADO | RISCO RESIDUAL |
|---|---|---|
| Spoofing | X.509 individual e TOTP no painel | TOTP pode ser capturado por phishing; WebAuthn é evolução |
| Tampering | SQL parametrizado, leitura restrita, aprovação | Sem ensaio com bomba física |
| Repudiation | Logs, hashes e custódia verificável | CMOS sem NTP; administrador do host pode reescrever cadeia |
| Information disclosure | Dados mínimos, RBAC e banco separado | Não é teste completo de invasão da aplicação |
| Denial of service | Alarme local e fila SQLite durável | Sem redundância de energia/disco validada |
| Elevation of privilege | Perfis no painel; redes/firewall testados | Sem SSH/RDP remoto; MFA protege o painel |

## Modo degradado implementado

Sem o coletor, a borda aceita mensagens válidas, aplica regras e acumula eventos na outbox. Ao receber ACK após o retorno, elimina apenas os IDs confirmados. O coletor ignora duplicatas pela chave primária. O comando de alto impacto permanece sob decisão da coordenação, sem decisão da IA.

## Redundância proporcional projetada

O RT-03 admite modo degradado justificado: não há link 4G funcional neste laboratório. Para implantação, foram orçados UPS e borda reserva compartilhada. Clusters por local foram descartados pelo custo e capacidade dos voluntários. Persistem pontos únicos por nó, pelo host comum e pela CA de desenvolvimento.

Planejamento de fila: 20 sensores, 1 leitura/10 s e 250 bytes por evento produzem 43,2 MB/dia de payload no conjunto. Com margem 4x, aproximadamente 173 MB/dia. O protótipo não implementa política de disco cheio; medir retenção e descarte controlado é pendência de robustez.

# Plano de testes e resultados executados

Foram executados **25/25** testes automatizados em processos locais, com diretório de estado exclusivo. Os resultados completos estão em evidence/security.json. Nenhum endereço de terceiro foi testado.

| Nº | VERIFICAÇÃO REALIZADA | RESULTADO |
|---|---|---|
| 1 | MQTT mTLS com identidade própria | APROVADO |
| 2 | Alarme local sem decisão da nuvem | APROVADO |
| 3 | Sem certificado | APROVADO |
| 4 | CA não confiável | APROVADO |
| 5 | ACL: certificado não publica por outro sensor | APROVADO |
| 6 | Revogação e rotação X.509 | APROVADO |
| 7 | Cliente independente Paho MQTT QoS1 | APROVADO |
| 8 | Sincronização HTTPS mTLS | APROVADO |
| 9 | Reconciliação idempotente UUID | APROVADO |
| 10 | SQLi antes/depois - tautologia | APROVADO |
| 11 | SQLi antes/depois - extração sintética | APROVADO |
| 12 | Reprodução do agendamento alterado | APROVADO |
| 13 | Validação e erro genérico | APROVADO |
| 14 | Senha sem segundo fator recusada | APROVADO |
| 15 | MFA operador | APROVADO |
| 16 | TOTP não reutilizável | APROVADO |
| 17 | MFA tecnico | APROVADO |
| 18 | MFA coordenacao | APROVADO |
| 19 | MFA auditor | APROVADO |
| 20 | Painel restrito sem autenticação | APROVADO |
| 21 | Proteção CSRF | APROVADO |
| 22 | RBAC auditor não comanda | APROVADO |
| 23 | Ação crítica exige coordenação | APROVADO |
| 24 | Quatro regras SIEM | APROVADO |
| 25 | SOAR isola certificado após violação da ACL | APROVADO |

# SQL Injection: exploração e correção

| TESTE | VERSÃO LEGADA | VERSÃO CORRIGIDA |
|---|---|---|
| p001 | Um registro esperado | Um registro esperado |
| ' OR 1=1 -- | Três registros retornados | Zero registros; texto tratado como valor |
| ' UNION SELECT id,name,role FROM users -- | Dois usuários fictícios extraídos | Zero registros |
| Alteração do agendamento | Hora da escola alterada para 2 | Banco seguro permaneceu em 8 |
| Entrada >80 caracteres | Não é a defesa da versão insegura | HTTP 400, mensagem genérica |

## Causa raiz e correção no código

```
Legado, apenas banco descartável:
SELECT id,person,event FROM history WHERE person='" + query + "'
```

```
Corrigido:
db.execute(
  "SELECT id,person,event FROM history WHERE person=?",
  (query,)
)
```

A conexão segura é aberta com mode=ro. O callback de autorização permite SELECT e leitura somente da tabela history; nega leitura de users e alterações. A entrada tem limite de tamanho e erros não expõem SQL, caminho de arquivo ou stack trace. A detecção por padrão agrega alerta, mas a parametrização é a proteção principal [R1].

O endpoint inseguro roda somente com --vulnerable, em 127.0.0.1:8081 e banco vulnerable.db. O painel seguro usa outro banco. A mudança de horário foi lógica; não houve bomba real nem acesso ao ambiente da FIAP.

# Certificados, MFA e controle de atuação

A PKI local emite CA própria e certificados de 90 dias. A rotação também foi testada no Mosquitto real: certificado antigo revogado por CRL assinada e novo serial aceito. A chave emissora não foi montada nos containers. Cada identidade possui sua chave. MQTT deriva o tópico do CN autenticado; HTTPS aceita somente edge-centro/escola/ubs/horta/abrigo e confere o site de cada evento. TLS exige pelo menos 1.2. Chaves privadas são geradas em .runtime e excluídas da publicação.

| EVIDÊNCIA | O QUE FOI OBSERVADO |
|---|---|
| Sem certificado / CA estranha | Conexão rejeitada e nenhuma nova leitura aceita |
| Identidade correta, tópico errado | Publicação negada por ACL e isolamento lógico daquela identidade |
| Revogação / rotação | Serial antigo bloqueado; novo certificado com mesmo CN e serial distinto aceito |
| MQTT independente | Paho recebeu PUBACK para QoS1; não se testou só cliente próprio |
| Reenvio HTTPS | Mesmo UUID reenviado: quantidade única permaneceu constante |

| PERFIL | PERMISSÃO |
|---|---|
| Operador | Consulta e solicita ação; não aprova |
| Técnico | Consulta e solicita ação; manutenção é atribuição projetada |
| Coordenação | Consulta, solicita e aprova ação de alto impacto |
| Auditor | Consulta; comando negado no teste |

Senhas usam PBKDF2-HMAC-SHA256, salt por usuário e 600 mil iterações; TOTP com janela de ±1 período, bloqueio de repetição e limite de tentativas. Cookies são HttpOnly/SameSite=Strict; token CSRF nas alterações. Secure/TLS para o painel remoto ainda depende de terminação HTTPS na implantação; o modo nativo fica em loopback.

# VPN e segmentação: piloto validado

**Execução comprovada:** após a instalação de Ubuntu 24.04/WSL2 e Docker Desktop, o piloto foi construído e executado. Handshake WireGuard, HTTPS mTLS pelo túnel e fluxos permitidos/proibidos foram conferidos. Resultados em evidence/docker/network.json e wireguard.txt.

| REDE DO PILOTO | ENDEREÇOS | POLÍTICA TESTADA |
|---|---|---|
| Transporte virtual | 172.29.0.0/24 | Somente UDP WireGuard; sem HTTPS direto ao coletor |
| Túnel WireGuard | 10.77.0.1 e .2 | Borda UBS para nuvem: TCP 9443 |
| IoT | 172.29.10.0/24 | Dispositivos → broker: TCP 8883; painel bloqueado |
| Operadores | 172.29.20.0/24 | Painel TCP 8080; broker bloqueado |
| Administração | 172.29.30.0/24 | Segmento distinto; sem SSH/RDP ou porta publicada |

O perfil piloto cobre uma UBS, com gerador de quatro identidades, Mosquitto e agente assinante, armazenando os mesmos eventos no SQLite. Dois gateways usam AllowedIPs /32, e o coletor recebe HTTPS apenas pela interface wg0. As redes de campo, operação, administração e túnel são internas. Uma ponte adicional publica somente o visualizador em 127.0.0.1:8088, com saída geral bloqueada por firewall. Não há porta publicada na LAN/Internet. Testes: docker/validate.py e docker/chaos.py [R2-R3].

## Testes executados e limites

O teste estruturado verificou painel acessível a operadores/administração, MQTT acessível a IoT e bloqueado a operadores, painel bloqueado a IoT e coletor bloqueado fora do túnel. O ensaio interrompeu a interface WireGuard por pelo menos 30 minutos, manteve leituras/alarmes e comparou os conjuntos de UUIDs após a reconciliação. A CRL Mosquitto foi assinada na estação emissora e recarregada por reinício controlado do broker.

O MFA atual é do painel. WireGuard autentica pares por chave; ele não oferece neste projeto um login humano MFA no túnel. Administração remota permanece desabilitada. Antes de oferecê-la, integrar portal/ZTNA/bastion com MFA. A inicialização usa root/NET_ADMIN para configurar a rede; os cinco processos principais da versão revisada executam como UID 1000, após abandono dos privilégios. Chaves privadas possuem permissão 600. O operador Docker do host ainda pertence à base de confiança.

# Phishing, autenticação de e-mail e pessoas

| MÉTRICA | CONTAGEM / 5 CONTAS | TAXA |
|---|---|---|
| Abertura | 4 | 80% |
| Clique | 3 | 60% |
| Submissao | 2 | 40% |
| Reporte | 2 | 40% |

Cinco agentes automáticos fictícios acessaram rotas HTTP locais instrumentadas. Não houve envio SMTP, usuários reais, voz clonada ou coleta de senha. As taxas verificam contadores do laboratório, não suscetibilidade humana nem eficácia do treinamento. Uma submissão é somente o evento de confirmação, sem conteúdo de credenciais.

## Zona fictícia vila-aurora.test

```
@ TXT "v=spf1 ip4:192.0.2.25 -all"
lab2026._domainkey TXT "v=DKIM1; k=rsa; p=<chave pública>"
_dmarc TXT "v=DMARC1; p=quarantine; adkim=s; aspf=s; pct=100"
```

O registro DKIM completo está em evidence/email-auth.json. Uma chave RSA específica de e-mail assinou a mensagem .eml; dkimpy verificou a assinatura com resolvedor DNS offline e rejeitou a alteração do corpo. SPF e DMARC foram documentados, sem um servidor de e-mail/receptor real para avaliar entrega, alinhamento e relatórios. A política DMARC exige autenticação alinhada e solicita quarentena quando falha [R4].

## Resposta ao phishing e à voz clonada

Voluntários recebem orientação para abrir o endereço já conhecido, conferir domínio e confirmar pedidos urgentes por contato previamente cadastrado, usando palavra-código por outro canal. Texto sem erros e áudio convincente não autenticam remetente. Reportar antes de excluir; preservar cabeçalhos e hash, sem reenviar senhas. Treinamento proposto de 15 minutos e revisão mensal, sem culpar vítimas.

# IA defensiva e avaliação crítica

O modelo foi treinado com 1.200 observações normais sintéticas. O teste separado contém 300 normais e 60 anomalias em temperatura, nível e energia. Sementes distintas tornam a avaliação reprodutível, sem ajustar o limiar depois de observar os resultados. O parâmetro contamination=0,03 foi definido antes do teste [R5].

**MATRIZ DE CONFUSÃO | conjunto de teste independente**

| | |
|---|---|
| Normal / normal<br>**294** | Normal / anomalia<br>**6** |
| Anomalia / normal<br>**22** | Anomalia / anomalia<br>**38** |

| INDICADOR | CÁLCULO | RESULTADO |
|---|---|---|
| Precisão | 38 / (38 + 6) | 86,36% |
| Revocação | 38 / (38 + 22) | 63,33% |
| Falsos positivos | 6 / (6 + 294) | 2,00% |

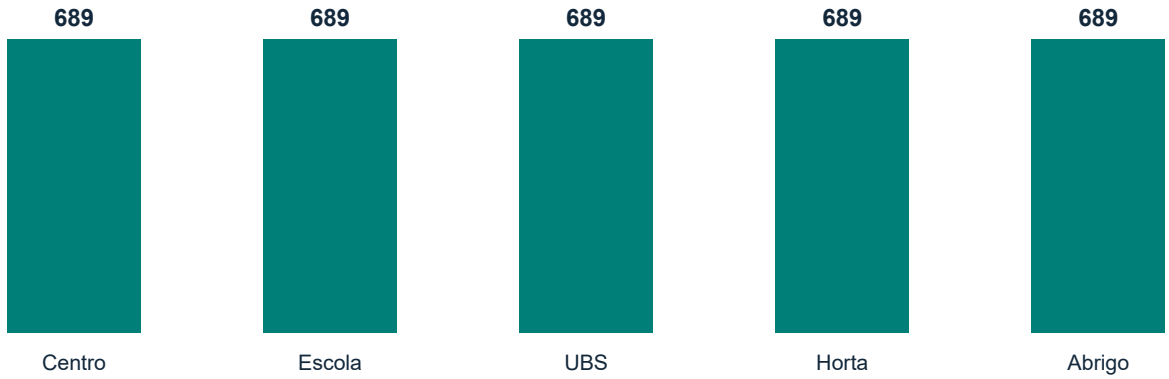
O modelo deixou de detectar 22 anomalias. Uma taxa baixa de falsos positivos não compensa esse risco em água/saúde. As regras determinísticas locais permanecem necessárias; a IA produz triagem offline, não decisão de segurança. Os dados não representam ruído real, sazonalidade, deriva de sensor ou ataques adversariais; avaliar essas condições é requisito de evolução.

Não há LLM na solução operacional. O RT-17 é condicional e não se aplica a esta implementação. Não se declarou teste de prompt injection contra um componente inexistente. Nenhum resultado da IA aciona atuadores.

# Continuidade: falha real do serviço coletor

| INDICADOR | RESULTADO MEDIDO |
|---|---|
| Coletor indisponível | 1802.000 s (30.03 min) |
| Publicações no período | 3440; falhas: 0 |
| Disponibilidade de ingestão local | 100.00% das tentativas amostradas |
| Eventos persistidos / nuvem única | 3445 / 3445 |
| Ausentes na reconciliação | 0 |
| Tempo de recuperação da fila | 26.015 s desde reinício do coletor |

Mensagens persistidas imediatamente antes do retorno do coletor




Depois da recuperação, todas as cinco filas chegaram a zero. As leituras continuaram durante a falha e houve alarmes locais. A duração usa time.monotonic; os horários de início/fim são do relógio do host, sem garantia NTP. O valor de disponibilidade descreve tentativas de publicação amostradas, não SLA anual nem uptime físico.

O processo HTTPS foi desligado e reiniciado, causando indisponibilidade real ao transporte local. O link WAN físico não foi derrubado neste primeiro ensaio. Um segundo experimento, apresentado a seguir, executou o corte real da interface WireGuard no piloto Linux; são dois cenários distintos.

# Recursos, detecção e respostas

| MEDIDA | VALOR / ESCOPO |
|---|---|
| CPU média do processo | 2.78% segundo psutil; cinco bordas lógicas juntas |
| RAM de pico | 44.06 MiB RSS do processo |
| Payload MQTT recebido | 214,198 bytes no conjunto; não inclui TLS/TCP/IP |
| Payload HTTPS confirmado | 573,358 bytes; não equivale a captura de enlace |
| Energia do nó físico | Não medida; hipótese de 15 W apenas no orçamento |

A amostragem mede o processo, sem isolamento de CPU/memória por borda. A medida de payload não inclui headers, handshakes, perdas e retransmissões TCP. Um wattímetro e captura de tráfego no nó Linux são necessários para completar os indicadores físicos do RT-22.

| REGRA | FONTE DO EVENTO | MTTD MÉDIO LOCAL |
|---|---|---|
| D01 | Login VPN anômalo (replay sintético) | 0.117 s |
| D02 | Padrão SQL Injection (HTTP real local) | 0.093 s |
| D03 | Certificado ausente/inválido (TLS real) | 0.241 s |
| D04 | Atuador fora do perfil (HTTP real local) | 0.146 s |

O correlacionador lê o log a cada 250 ms. MTTD é diferença entre emissão do evento e registro de detecção no mesmo host; não é tempo da intrusão original. Uma violação da ACL revoga somente o certificado autenticado do sensor e registra isolamento lógico. Isso foi testado. Encerrar VPN/bloquear IP externo não foi executado.

O MTTR de continuidade mede esvaziamento da fila após reinício. Não mede restauração do incidente cibernético inteiro. Para bomba/portas, a automação cria solicitação pendente e a coordenação aprova. O teste automatizado apenas verificou essas permissões e a mudança de estado lógico.

# Laudo do incidente reproduzido

**Identificação:** INC-VA-0712-LAB-RM552505. Este é um laudo acadêmico da reprodução parcial e controlada; não atribui autoria nem afirma examinar o incidente histórico fictício. O objeto foi a exploração SQLi, alteração de um agendamento sintético, autenticação, detecção e continuidade local.

| ETAPA | PROCEDIMENTO EXECUTADO |
|---|---|
| Preservação | Testes em estado separado; bancos e entradas exclusivamente sintéticos; chaves privadas fora da pasta pública |
| Aquisição | Cópia lógica dos logs fechados e resultados; sem imagem de disco/memória |
| Integridade | SHA-256 individual e conferência da cadeia JSONL; manifesto acompanha os arquivos |
| Exame | Comparar respostas legada/corrigida, horário da bomba e eventos de autenticação/detecção |
| Relato | Separar fato executado, replay sintético e configuração não executada |

A aquisição foi feita por script autorizado, sob responsabilidade acadêmica do RM552505. Registro de coleta no relógio do host: **2026-11-12T04:51:51.723+00:00**. O arquivo custody.json registra quem, quando, origem, método e limites. A publicação Git será um evento posterior, não foi retroativamente incluída como transferência já realizada.

## Qualidade temporal e integridade

A consulta w32tm mostrou indicador 3, camada 0 e fonte Local CMOS Clock. Portanto, os UTCs não têm exatidão externa demonstrada. A ordem causal do laboratório se apoia na sequência e em monotonic_ns. Reproduzir em hosts diferentes exigirá NTP validado antes de correlacionar horários.

continuity-events.jsonl: cadeia ÍNTEGRA, 3560 registros. Hash terminal completo no arquivo chain-verification.json.

security-events.jsonl: cadeia ÍNTEGRA, 45 registros. Hash terminal completo no arquivo chain-verification.json.

Hashes detectam alteração em relação ao manifesto preservado; não garantem autoria, relógio correto ou inviolabilidade do host. Um administrador pode reescrever uma cadeia inteira. Manter o manifesto em cópia independente e preservar o commit entregue.

# Inventário e linha do tempo

**evidence/ai.json** | 682 bytes

`437c5c887d8523889125ed858eb393cbba7a52f27c6238ad2d2d360eb85f67c2`

**evidence/chaos.json** | 17896 bytes

`a998fd077c827eddbf666258b5a7ba5b25c84bbece1cc484d71eacb273de3896`

**evidence/detections.json** | 2972 bytes

`f60ca123bea4e8991c54f459afa83e733d9cadb6ce06abd4bd6939946929f42a`

**evidence/forensics/continuity-events.jsonl** | 1384425 bytes

`639ac899158c2b9a3ec11ee5355fb485bbcd787edbf1a58b930b1cf7b9989f37`

**evidence/forensics/security-events.jsonl** | 16278 bytes

`7a295b80ecf8d7b65cfd7a81ec15afd8293c4d55d0961e8594df17b9aa167c72`

**evidence/security.json** | 6904 bytes

`19372f191367be04b418e36e0422157f9e71ed712387c027ac652527318bff8a`

O manifesto integral em evidence/forensics/manifest.sha256 permite verificar os arquivos sem depender deste PDF. A captura do painel é ilustrativa da interface, com login real e dados lidos do ensaio em andamento; não substitui os logs e resultados.

| HORÁRIO DO HOST (UTC) | MARCO | NATUREZA |
|---|---|---|
| 01:30:32.669+00:00 | SQLi enviada e detectada | local_execution |
| 01:30:32.748+00:00 | Agendamento sintético alterado | local_execution |
| 01:30:33.254+00:00 | Login MFA aceito | local_execution |
| 01:30:34.249+00:00 | Comando negado por perfil | local_execution |
| 01:30:34.289+00:00 | Aprovação muda estado lógico | local_execution |
| 01:30:34.302+00:00 | Login VPN fictício injetado no correlacionador | synthetic_replay |

A sequência representa o roteiro de teste e não a cronologia narrativa do incidente original às 02h14. O replay da VPN foi inserido depois para testar a regra D01; não houve login real em VPN. Datas e horários não foram ajustados para parecer o incidente histórico.

# Conclusões forenses e MITRE ATT&CK;

| TÉCNICA | RELAÇÃO COM O CENÁRIO | STATUS DA EVIDÊNCIA |
|---|---|---|
| T1566.002 - Spearphishing Link | Link malicioso da narrativa | Modelo .eml e agentes locais; sem vítima humana |
| T1078 - Valid Accounts | Credencial capturada reutilizada | Premissa do incidente; não reproduzido em túnel |
| T1133 - External Remote Services | Entrada pela VPN legada | Replay sintético para detecção |
| T1005 - Data from Local System | Leitura de usuários no banco local | UNION devolveu dois usuários fictícios |
| T1565.001 - Stored Data Manipulation | Mudança do agendamento no banco | Hora 2 no legado e 8 no seguro |

O mapeamento é uma interpretação técnica do comportamento e não uma identificação de agente, campanha ou malware. T1190 não foi usado para rotular a exploração do painel interno, pois não foi demonstrado serviço publicamente exposto. Stored Data Manipulation contempla alterações em dados em repouso que mudam resultados de negócio [R6].

## Conclusões sustentadas pelas evidências

A concatenação permitiu ampliar a consulta e extrair dados fictícios. A parametrização, a leitura restrita e a separação de bases impediram os mesmos efeitos na versão segura. O agendamento inseguro foi alterado somente no banco descartável. Certificado e perfil indevidos foram recusados; a decisão crítica exigiu aprovação de coordenação no estado lógico.

Não se comprovou extração de dados reais, invasão externa, falha física de equipamento, queda da fibra ou comprometimento de uma rede institucional. A ausência desses testes não pode ser substituída por inferência a partir dos resultados locais.

## Prioridade de correção

1. Confirmar sincronismo NTP e validar coleta contínua autenticada de logs entre hosts. 2. Adicionar acesso administrativo com MFA antes de oferecer SSH/RDP remoto. 3. Medir energia física, disco cheio e restauração. 4. Revalidar telemetria e IA com sensores calibrados. VPN, segmentação, revogação Mosquitto e execução sem root já possuem evidência do piloto.

# Interface, privacidade e viabilidade

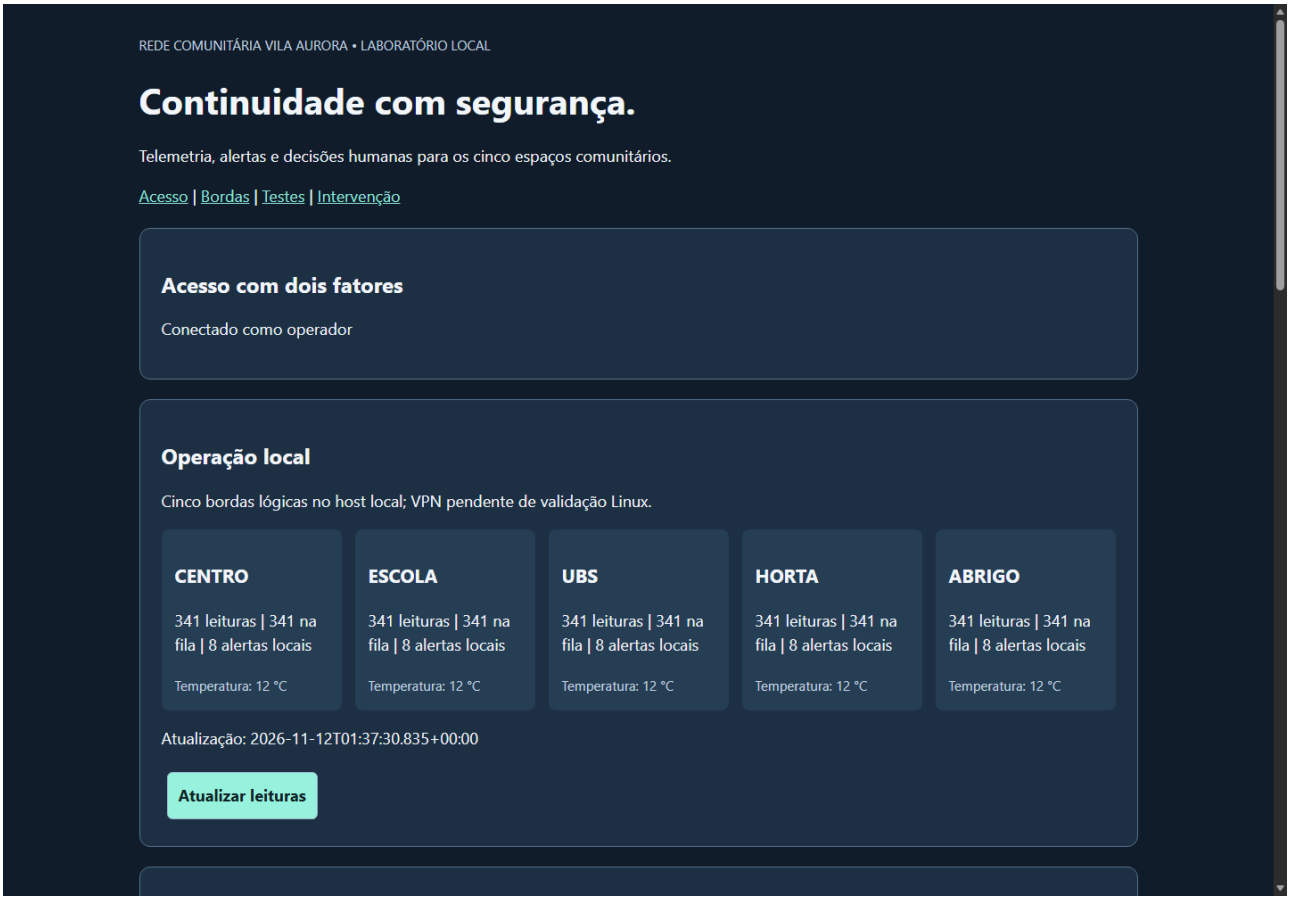



Figura: captura do painel local em navegador de teste, após login MFA e com cinco cartões de borda; estado capturado durante o ensaio. Idioma pt-BR, rótulos nativos, foco visível e link de salto foram implementados. O teste de interface confirmou login e renderização; não certifica a jornada completa WCAG 2.1 AA [R7].

## RIPD e minimização

Somente dados sintéticos foram usados. No produto, registros de acesso devem ser pseudonimizados, com tabela de correspondência separada, finalidade definida e retenção limitada. Pseudonimização não equivale a anonimização. Propõem-se 30 dias para telemetria e 90 para segurança/backup, sujeitos à validação do controlador; expurgo automático ainda não foi implementado.

A base legal deve ser escolhida segundo finalidade e vínculo do controlador. Legítimo interesse para associação privada é hipótese a avaliar, não autorização genérica. Não há dados de saúde neste laboratório. Riscos residuais: reidentificação por horário, retenção excessiva e controle central do host. Ver RIPD simplificado em docs/OPERACAO.md e texto vigente da LGPD [R8].

# Orçamento e manutenção

| ITEM DE PLANEJAMENTO | VALOR |
|---|---|
| 5 bordas com armazenamento | R$ 3.250,00 |
| 5 UPS | R$ 1.750,00 |
| Rede, caixas e cabos | R$ 1.000,00 |
| Sensores/interfaces de laboratório | R$ 1.250,00 |
| Borda reserva + instalação | R$ 1.370,00 |
| Implantação estimada | R$ 8.620,00 |
| 12 meses: hospedagem/backup | R$ 720,00 |
| 12 meses: manutenção | R$ 1.440,00 |
| 12 meses: energia estimada | R$ 722,70 |
| Total implantação + 12 meses | R$ 11.502,70 |
| Com contingência de 15% | R$ 13.228,11 |

Valores são hipóteses de orçamento, não cotações comerciais. Energia usa 5 nós x 15 W x 24 h x 365 dias / 1.000 x R$1,10/kWh. Não foi medida no host. Fibra existente foi pressuposta; 4G, adequação elétrica e certificações não estão incluídos. Cotar antes de adquirir hardware.

| RESPONSÁVEL PROPOSTO | ROTINA |
|---|---|
| Operador local | Verificação diária de alertas e fila; reporte de mensagens suspeitas |
| Técnico | Backup diário, restauração mensal, atualização controlada mensal e inventário |
| Coordenação | Aprovação crítica e revisão mensal de acessos/custos |
| Auditor | Revisão de trilhas, retenção e hashes |
| Responsável PKI | Renovar antes de 60 dias em certificados de 90; revogar imediatamente por incidente |

Essas rotinas são plano de operação profissional. O laboratório gerou identidades e provou rotação/revogação no broker nativo e no Mosquitto; não executou um ano de manutenção, backup diário ou atualização de firmware real.

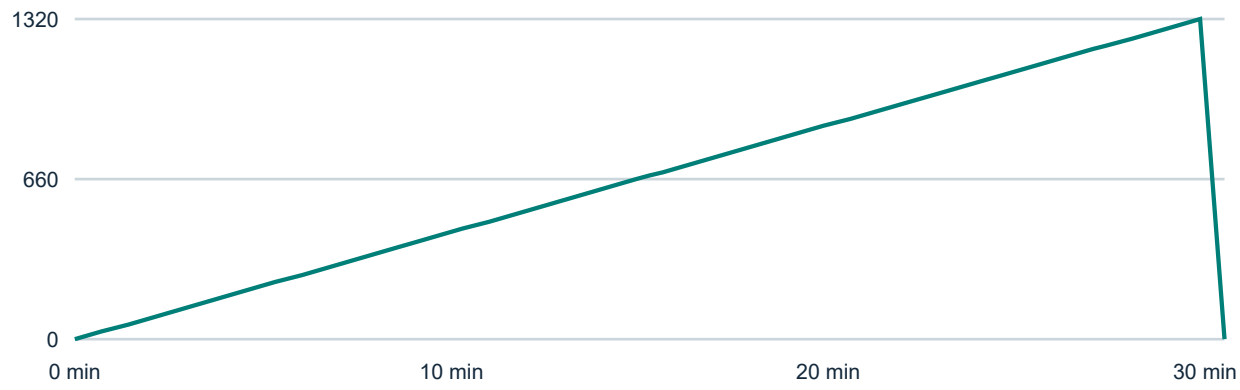
# Rastreabilidade dos requisitos

| RT | SITUAÇÃO | EVIDÊNCIA / LIMITAÇÃO |
|---|---|---|
| 01 | Parcial | Cinco bordas lógicas; host/processo compartilhado |
| 02 | Testado local | MQTT, regras, fila SQLite e reconciliação |
| 03 | Documentado/funcional | Modo degradado; sem 4G ou UPS instalado |
| 04 | Testado local | 20 identidades distintas; mTLS MQTT/HTTPS |
| 05 | Testado local/Linux | Lista de bloqueio + CRL Mosquitto e novo serial |
| 06 | Testado no escopo | VPN borda-nuvem; MFA no painel; sem administração remota |
| 07 | Testado Linux | 3 segmentos; caminhos permitidos e negados conferidos |
| 08 | Testado local | SQLi antes/depois, parâmetros e leitura restrita |
| 09 | Testado local | Quatro perfis, senha + TOTP |
| 10 | Testado offline | SPF/DKIM/DMARC: registros e 9 verificações no laboratório |
| 11 | Testado em agentes | 5 contas fictícias; sem medição humana |
| 12 | Parcial | Logs centrais; NTP ausente, VPN só replay |
| 13 | Testado com ressalva | 4 regras; D01 usa replay sintético identificado |
| 14 | Executado local | Aquisições nativa/Linux, hashes, custódia e timeline |
| 15 | Testado lógico | Revoga sensor; ação crítica exige coordenação |
| 16 | Executado offline | Isolation Forest e métricas em dataset sintético |
| 17 | Não aplicável | Sem LLM na solução operacional |
| 18 | Documentado | Phishing IA/voz e verificação fora de banda |
| 19 | Documentado/aplicado | Dados sintéticos; RIPD e retenção projetada |
| 20 | Documentado | Hipóteses de custo e manutenção por responsáveis |
| 21 | Testado parcialmente | Teclado, contraste, 320 px e ampliação: 9 verificações |
| 22 | Parcial | CPU/RAM/rede medidos; cenário energético sintético calculado |
| 23 | Testado no piloto | 30 min de corte do túnel virtual; sem fibra física |

# Interrupção do túnel no piloto Linux

| INDICADOR DO ENSAIO DE 30 MINUTOS | RESULTADO |
|---|---|
| Duração monotônica com wg0 desligada | 1802.000 s |
| Novas leituras persistidas durante o corte | 1328 |
| Novos alarmes locais no período | 41 |
| Eventos novos recebidos na nuvem durante o corte | 0 |
| Tempo de recuperação da fila | 28.914 s |
| Mensagens ausentes / inesperadas | 0 / 0 |
| Mensagens pendentes ao final | 0 |
| Amostras com progresso local entre consultas | 100.00% |

**FILA DURÁVEL DA UBS | amostras reais durante o corte e após reconciliação**




O ensaio derrubou a interface de rede WireGuard do container da UBS, mantendo o tráfego IoT local. O gerador de campo foi congelado somente após o período exigido para comparar conjuntos de UUIDs estáveis; depois foi retomado. Não houve corte de fibra, falha de energia nem teste de cinco links físicos.

O núcleo de fila/regras permaneceu o mesmo. Após o ensaio longo da versão-base, a versão revisada acrescentou CRL, processos sem root e visualizador; uma regressão curta do corte e os testes de segurança foram realizados novamente. Os arquivos mantêm a distinção entre essas fases.

# TLS real, isolamento e revisão final

| TESTE MOSQUITTO REAL | EVIDÊNCIA |
|---|---|
| Certificado válido e tópico permitido | PUBACK MQTT5 de sucesso |
| Cliente sem certificado | Autenticação TLS recusada |
| Cliente assinado por CA não confiável | Autenticação TLS recusada |
| Certificado válido em tópico de outro dispositivo | PUBACK 135: não autorizado |
| Serial antigo após CRL | Conexão recusada |
| Mesmo dispositivo com novo serial | Publicação aceita |

A chave da CA ficou na estação emissora Ubuntu. O broker recebeu somente certificados, chave própria e CRL pública. O certificado de teste antigo continuou no diretório privado apenas para o reteste; não foi versionado. O reinício controlado recarregou o contexto TLS. A sessão MQTT antiga não é apresentada como revogada por mágica: o processo foi reiniciado e os clientes reconectaram.

```
Serial antigo: 519cee0499471b389ee1a437dab820b2199331c6
Novo serial:   55e98d2431bf3b36572fabce28d03d8db3168f8f
```

| MEDIDA DO CONTAINER DA BORDA | VALOR / ESCOPO |
|---|---|
| CPU média / pico | 0.605% / 2.190% pelo docker stats |
| Memória - primeira e última amostras | 30.78MiB / 7.719GiB → 33.9MiB / 7.719GiB |
| Rede | Contadores NetIO/WireGuard preservados no JSON; não equivalem a wattímetro ou captura completa de enlace |
| Regressão loopback em Linux | 25/25 testes aprovados |
| Rede e privilégios | 9/9 verificações aprovadas |

Relógios: systemd-timesyncd contactou ntp.ubuntu.com e registrou sincronização inicial; timedatectl ainda mostrou System clock synchronized: no. Portanto, a exatidão absoluta não é assumida. O ensaio usa contador monotônico. Energia elétrica física segue não medida. Logs e metadados desta fase foram adquiridos logicamente e incluídos no manifesto SHA-256 atualizado.

# Escopo permitido e energia do cenário

O enunciado permite dispositivos em containers ou simuladores e informa, na página 10, que hardware real é um diferencial, não uma obrigação. Portanto, o protótipo não exige montar uma placa, sensor físico ou equipamento externo. As verificações de software e rede deste relatório foram executadas no laboratório próprio.

## Requisito de VPN e acesso administrativo

O RT-06 exige VPN moderna entre borda e nuvem e condiciona o acesso administrativo remoto a VPN/ZTNA com MFA. O piloto comprova WireGuard entre os nós e não oferece SSH/RDP remoto. As contas humanas do painel usam senha e TOTP. Isso não é uma alegação de MFA humano nativo no protocolo WireGuard. Antes de oferecer administração remota, será necessário implantar e testar esse controle adicional.

## Cenário sintético calculado de consumo

A potência abaixo é uma hipótese explícita de projeto; não é dado de wattímetro nem consumo inferido da CPU. Somente a duração do ensaio, 1802,000 segundos, foi medida. O cenário de 15 W é o mesmo usado no orçamento; 8 e 25 W mostram sensibilidade da estimativa.

| POTÊNCIA HIPOTÉTICA | UMA BORDA / ENSAIO | CINCO BORDAS / ENSAIO | CINCO BORDAS / ANO |
|---|---|---|---|
| 8 W | 4.0044 Wh | 20.0222 Wh | 350.4 kWh |
| 15 W | 7.5083 Wh | 37.5417 Wh | 657.0 kWh |
| 25 W | 12.5139 Wh | 62.5695 Wh | 1095.0 kWh |

```
E (Wh) = P média (W) x duração (s) / 3600
E = 15 x 1802,000 / 3600 = 7,5083 Wh por borda
E anual = 5 x 15 x 24 x 365 / 1000 = 657 kWh
```

A multiplicação por cinco representa uma futura implantação de cinco nós independentes. Não significa que cinco equipamentos físicos foram medidos. A energia permanece estimada em RT-22, enquanto CPU, memória, contadores de tráfego, duração e perda de mensagens têm evidências de execução. Reproduzir o cálculo: python tools/estimate_energy.py.

**Classificação:** cenário energético sintético calculado. A utilização de um laboratório virtual é permitida pelo enunciado; a estimativa não será apresentada como medição física.

# Verificações complementares executadas

| AUTENTICAÇÃO DE E-MAIL OFFLINE | RESULTADO |
|---|---|
| SPF: IP autorizado / IP indevido | pass / fail pelo avaliador pyspf 2.0.14 |
| DKIM: mensagem íntegra / corpo adulterado | Assinatura aceita / recusada por dkimpy |
| DMARC: SPF alinhado ou DKIM alinhado | Aprovação pelos casos positivos |
| DMARC: falha ou ausência de alinhamento | quarantine nos três casos negativos |
| Total de verificações | 9/9 aprovadas |

Os registros do domínio fictício foram resolvidos em memória, sem publicar DNS real, enviar SMTP ou envolver pessoas. O avaliador DMARC verifica o alinhamento estrito definido em adkim=s e aspf=s; não implementa um receptor SMTP completo nem gera relatórios de provedores. O domínio .test permanece intencionalmente offline. Script: tests/run_email_auth.py.

| ACESSIBILIDADE EM NAVEGADOR REAL | RESULTADO |
|---|---|
| Idioma português e título identificável | Aprovado |
| Rótulos nativos dos três campos | Aprovado |
| Link de salto alcançável por Tab e ativa conteúdo | Aprovado |
| Foco visível por teclado | Aprovado |
| Login MFA concluído somente com teclado | Aprovado |
| Contraste mínimo 4,5:1 nos seis pares selecionados | Aprovado |
| Refluxo a 320 CSS px sem rolagem horizontal | Aprovado |
| Ampliação CSS 200% sem rolagem horizontal | Aprovado |
| Mensagens de estado com anúncio acessível | Aprovado |

Foram corrigidos rótulos explícitos, foco do link de salto e refluxo do layout. Menor contraste entre os seis pares selecionados: 10.19:1. A ampliação foi testada com zoom CSS de 200%; largura de 320 CSS px foi conferida separadamente. São verificações selecionadas, sem certificação integral WCAG nem ensaio com leitor de tela/usuários. Evidência: evidence/review/accessibility.json.

## Horário: pendência real preservada

A revisão confirmou W32Time parado no Windows e diferença próxima de 22 segundos para time.windows.com. A sessão não possui elevação administrativa para iniciar esse serviço. Nenhuma hora foi definida manualmente e os horários antigos não foram reescritos. O script docs/AJUSTAR_HORARIO_WINDOWS.ps1 reúne os comandos para execução pelo usuário como administrador; após sincronizar, uma nova coleta deve ser identificada separadamente.

# Reprodução, fontes e uso de IA

Repositório público autorizado pelo autor:
github.com/CaioOzaki/GS2026-2-Cybersecurity-VilaAurora

O README contém instalação local, testes e limites. O guia docs/DOCKER_WINDOWS.md explica como reproduzir o piloto já validado. O roteiro docs/ROTEIRO_VIDEO.md propõe cerca de 4min50s com demonstração real. O enunciado menciona vídeo na rubrica, sem duração explícita; confirmar o limite com o professor. O vídeo ainda não foi gravado e seu link não foi inventado.

## Uso de IA

OpenAI Codex/ChatGPT apoiou arquitetura, código, automação dos testes, revisão e redação. As métricas vêm dos arquivos produzidos nas execuções descritas. O responsável acadêmico deve revisar e reproduzir o conteúdo e conseguir explicá-lo. IA generativa não integra o controle de atuadores; a IA defensiva do projeto é o Isolation Forest, avaliado offline.

## Referências primárias

[R1] Python Software Foundation. sqlite3: parâmetros e acesso ao SQLite. Acessar fonte. Consulta: novembro de 2026.

[R2] WireGuard. Quick Start: interfaces, chaves e peers. Acessar fonte. Consulta: novembro de 2026.

[R3] Eclipse Mosquitto. mosquitto.conf: TLS, identidade e ACL. Acessar fonte. Consulta: novembro de 2026.

[R4] IETF. RFC 7489: DMARC. Acessar fonte. Consulta: novembro de 2026.

[R5] scikit-learn. IsolationForest: documentação da API. Acessar fonte. Consulta: novembro de 2026.

[R6] MITRE ATT&CK. T1565.001: Stored Data Manipulation. Acessar fonte. Consulta: novembro de 2026.

[R7] W3C. WCAG 2.1: Quick Reference. Acessar fonte. Consulta: novembro de 2026.

[R8] Brasil. Lei nº 13.709/2018: LGPD, texto compilado. Acessar fonte. Consulta: novembro de 2026.

Fonte do cenário e requisitos: FIAP. GS2026.2 - Desafio Resilient Community Infrastructure. Prof. Carlos Eduardo de Siqueira, 11 páginas, material fornecido pelo autor. Evidências técnicas: scripts e arquivos do próprio laboratório, com hashes no manifesto.